VOLUME 2: MY GEOPOLITICAL THREAT INTELLIGENCE DOSSIER

Scope and Purpose

APT29 is the principal external threat actor assessed in this dossier. I examine its reported objectives and techniques, then use my homelab to explore related security questions through an insider-risk scenario, ATT&CK mapping, STIX/TAXII research and an IPv6 configuration case study. Volume 1 documents the infrastructure I built; Volume 3 records the tests and Splunk results discussed here.

My Strategic Advisory Briefing (Profiling the Risk of APT29)

Key judgement: A UK professional services firm handling sensitive government or technology work should consider APT29 in its espionage risk assessment. A compromise could expose confidential client information and strategic advice.

- **The Threat Profile:** I chose to profile **APT29**, also known as *Cozy Bear* and *Midnight Blizzard*. The UK National Cyber Security Centre assesses that this cyber espionage group is almost certainly part of Russia's Foreign Intelligence Service (SVR).
- **The Strategic Risk:** APT29 has targeted organisations with access to information of intelligence value, including government bodies, diplomatic organisations, think tanks and IT service providers. For my briefing, I considered a UK professional services firm operating in London or the Thames Valley. If that firm advised government clients or worked with sensitive technology, its client correspondence, legal advice and strategic plans could make it an attractive intelligence target.
- **My approach:**
  I built the briefing to explain what an APT29 intrusion could mean for the firm beyond the immediate technical breach. I considered the confidential information it might hold, the clients who could be affected and the consequences of that information reaching a foreign intelligence service. I then presented the threat in terms a board could use to assess its exposure and decide what information and relationships needed the strongest protection.

  I used the environment documented in Volume 1 as a practical reference point. Its domain controller, client workstation and central logging server gave me

specific identity and monitoring controls to consider when assessing the threat. I did not simulate an APT29 intrusion; the briefing applies published threat intelligence to the kind of environment I built.

My Operational TTP Matrix (Mapping Adversary Traits to Controls)

Key judgement: My lab's centralised authentication logs could help investigate misuse of a valid account, but the lab did not collect the email or exploit data needed to assess the other APT29 techniques in this matrix.

- **The Threat Profile:** I mapped selected techniques that MITRE ATT&CK associates with APT29, including spearphishing links, the use of compromised accounts and exploitation for privilege escalation. These are documented behaviours from different operations, not a fixed sequence that every APT29 intrusion follows.
- **The Operational Reality: T1078 (Valid Accounts)** describes an attacker using an account they have compromised to gain or maintain access. **T1068 (Exploitation for Privilege Escalation)** describes exploiting a software vulnerability to obtain higher permissions on a system. APT29 has been associated with both techniques. An attacker using a valid account may appear to be an ordinary user at first, which makes the context of their activity important when investigating logs.

Technique	Relevance to my Volume 1 lab
Spearphishing link (T1566.002)	My lab did not collect email activity, so its Splunk logs could not show the delivery of a phishing message.
Valid Accounts (T1078)	The Windows and Linux forwarders collected selected authentication logs. These gave me a place to examine account activity, subject to what each system recorded and forwarded.
Exploitation for Privilege Escalation (T1068)	I configured local account permissions and ran Splunk under a non-root account. Those choices limited routine privileges, but I did not test an exploit or build a detection for this technique.

- **My approach:**
  I used the matrix to connect published APT29 techniques to the controls I had built in Volume 1. It helped me identify where my centralised logs could support

an investigation, particularly around account use, and where the lab had gaps. My Splunk search confirmed that events from both machines reached the central index; it did not establish that I could detect an APT29 intrusion. That distinction gave me a more useful basis for recommending further monitoring.

My Insider Threat Behavioural Matrix (The Human Risk)

Key judgement: A denied attempt by a standard user account to run an administrative command is an event worth investigating. The event shows what the account tried to do; it does not, on its own, establish whether the person using it was malicious, mistaken or carrying out an authorised test.

- **The Threat Profile:** I considered two possible sources of risk: an employee misusing their own account and an attacker using a compromised employee account. Both could operate through an account that already has legitimate access to a workstation, making account activity an important source of evidence.
- **The Technique Mapping:** MITRE ATT&CK describes the misuse of legitimate accounts as T1078 (Valid Accounts). An attempt to obtain password hashes from “/etc/shadow” relates to T1003.008 (OS Credential Dumping: “/etc/passwd” and “/etc/shadow”). In the later, denied test, the command stopped at the permission check. I did not access or extract the password hashes.
- **The Lab Test:** I removed “corp-user” from the Ubuntu workstation’s “sudo” group. I then signed in as that user and attempted “sudo cat /etc/shadow”. The command was denied before the file could be read, and I found the denied attempt in Splunk.

- **My approach:**
  I used this test to connect an insider risk scenario to an event I could actually inspect. The access restriction worked, and the denial was available for investigation from my separate logging server. In a real organisation, an analyst would need more context before deciding whether a similar event indicated misuse. My lab demonstrated a working restriction and a visible audit trail, which are the starting points for that investigation.

My Research into STIX and TAXII Threat Sharing

Key judgement: STIX provides a structured way to describe threat intelligence, while TAXII provides a way to exchange it between systems. Sharing that data does not automatically create a detection or a blocking rule; the receiving organisation must decide how to use it.

- **The Threat Profile:** I researched how intelligence about an actor such as APT29 could be represented for sharing with other security teams. I considered how an actor's identity, documented behaviour and supporting information might be connected in a structured intelligence record.
- **The Operational Reality:** Security teams use both written briefings and machine-readable intelligence. STIX defines the structure of the data; TAXII can carry that data between compatible systems. A SIEM might use a received record to add context to an investigation or support a detection, depending on its configuration. Any automated response would need a separate rule and appropriate checks.
- **My approach:**
  I used the denied "sudo cat /etc/shadow" attempt from my lab to think through the difference between an observed event and a threat indicator. Splunk recorded the denied command, but that command alone did not identify APT29 or prove that an account was compromised. This exercise helped me understand why structured intelligence needs clear sources and relationships, and why an analyst must assess its meaning before using it to drive a defensive action.

My MITRE ATT&CK Mapping Ledger (Lab Events)

Key judgement: The authentication and "sudo" tests on "CORP-CL-01" produced events I could find in Splunk. I used MITRE ATT&CK to describe the behaviours those events represented and to connect the technical tests to a security analyst's investigation.

- **The Threat Profile:** I focused on attempts to access a local account and to read a protected file using elevated permissions. These behaviours matter because an attacker with access to a workstation might try to obtain credentials or use permissions that an account should not have.
- **The Lab Sequence and ATT&CK Mapping:**
  - Failed password attempts - T1110.001 (Password Guessing): I entered five incorrect passwords while using "su" to access the local "corp-user" account, then repeated the test with a nonexistent account. I searched Splunk for "authentication failure" and found the resulting events. The test

showed that repeated local authentication failures were reaching the central logging server.
    - Access to “/etc/shadow” - T1003.008 (OS Credential Dumping: “/etc/passwd” and “/etc/shadow”): I ran “sudo cat /etc/shadow” while “corp-user” still belonged to the “sudo” group. The command succeeded, and I found its record in Splunk. This showed that the account’s existing permissions allowed it to read a file containing password hashes. The use of “sudo” also made T1548.003 (Sudo and Sudo Caching) relevant when considering how elevated commands could be used on this workstation.
    - Permission change and repeat test: I removed “corp-user” from the “sudo” group, started a fresh session and ran “sudo cat /etc/shadow” again. The command was denied. I found the denial in Splunk, and a saved alert later matched it. This let me verify both the access restriction and the visibility of an attempt to use “sudo” without the required permission.
- **My approach:**
  I began by looking at the events I had generated on the Linux workstation and the searches that found them in Splunk. The first “sudo” test revealed that “corp-user” could read “/etc/shadow”, so I removed the account’s administrative group membership and repeated the test. This time the command was blocked, and I could still investigate the attempt through the central logs. Mapping these results to MITRE ATT&CK helped me explain why the password failures and access to a protected file would matter to an analyst, while the before-and-after test showed the practical effect of correcting the account’s permissions.

The Architectural Defence: IPv6 Configuration on the Domain Controller

Key judgement: Disabling IPv6 on the active network adapter of “CORP-DC-01” helped me keep this part of my lab on its planned IPv4 configuration while I investigated domain connectivity. It also reduced the server’s exposure to IPv6 traffic that I was not using or monitoring.

- **The Threat Profile:** In a network where IPv6 is active but poorly monitored, rogue router advertisements or DHCPv6 responses can supply misleading network settings, including routes or DNS information. This can create an overlooked path for traffic that administrators expect to follow their IPv4 configuration. I considered that risk when reviewing the attack surface of my domain controller.
- **The Operational Reality:** My lab used the “10.0.5.0/24” IPv4 network, with “CORP-DC-01” assigned “10.0.5.10”. While troubleshooting domain connectivity and name resolution, I unticked IPv6 on the server’s active network adapter. I then ran “ipconfig /flushdns” and “nslookup apex-corp.local”. The lookup returned

"10.0.5.10", confirming that the domain name resolved to the IPv4 address I had assigned to the server.

- **The Architectural Decision:** Removing the IPv6 binding reduced the ways this particular network interface could receive or use IPv6 configuration. It made the domain controller's network setup easier for me to inspect and reduced exposure to an unused protocol on that interface. I documented it as a decision for this IPv4-based lab and this server, alongside the connectivity checks I performed.
- **My approach:**
  I was trying to get the domain controller communicating reliably within the network I had built. I had assigned it a fixed IPv4 address, so I reviewed the active adapter while investigating its domain and DNS behaviour. Unticking IPv6 simplified that configuration, and the DNS flush and lookup let me check the result against the address I expected. My threat intelligence research gave the decision a second purpose: it prompted me to consider how an active, unmonitored IPv6 path could affect an identity server. This case study connects that risk assessment to a specific configuration change I made and checked in Volume 1.

Sources Consulted

1. **UK National Cyber Security Centre (NCSC).** "SVR cyber actors adapt tactics for initial cloud access." 26 February 2024. Used for APT29 attribution, intelligence objectives and documented account-access techniques. https://www.ncsc.gov.uk/news/svr-cyber-actors-adapt-tactics-for-initial-cloud-access
2. **UK National Cyber Security Centre (NCSC).** "Advisory: APT29 targets COVID-19 vaccine development." 16 July 2020. Used for an example of APT29 targeting organisations in the UK to obtain research and intellectual property. https://www.ncsc.gov.uk/news/advisory-apt29-targets-covid-19-vaccine-development
3. **Microsoft Threat Intelligence.** "Midnight Blizzard: Guidance for responders on nation-state attack." 25 January 2024. Used for a documented case involving password spraying, compromised accounts and subsequent access to information. https://www.microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-for-responders-on-nation-state-attack/
4. **Microsoft Threat Intelligence.** "Midnight Blizzard conducts targeted social engineering over Microsoft Teams." 2 August 2023. Used for an example of the group's targeted social engineering and credential-focused activity. https://www.microsoft.com/en-us/security/blog/2023/08/02/midnight-blizzard-conducts-targeted-social-engineering-over-microsoft-teams/
5. **MITRE ATT&CK.** "APT29 (G0016)." Last modified 31 July 2026. Used for the group profile, aliases and documented techniques. https://attack.mitre.org/groups/G0016/

6. **MITRE ATT&CK.** Enterprise technique definitions used in the TTP matrix and lab mapping:
    - Valid Accounts (T1078): https://attack.mitre.org/techniques/T1078/
    - Exploitation for Privilege Escalation (T1068): https://attack.mitre.org/techniques/T1068/
    - Password Guessing (T1110.001): https://attack.mitre.org/techniques/T1110/001/
    - Sudo and Sudo Caching (T1548.003): https://attack.mitre.org/techniques/T1548/003/
    - "/etc/passwd" and "/etc/shadow" (T1003.008): https://attack.mitre.org/techniques/T1003/008/
    - Spearphishing Link (T1566.002): https://attack.mitre.org/techniques/T1566/002/
7. **OASIS Cyber Threat Intelligence Technical Committee.** "STIX Version 2.1." OASIS Standard, 10 June 2021. Used for the explanation of structured, machine-readable threat intelligence. https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html
8. **OASIS Cyber Threat Intelligence Technical Committee.** "TAXII Version 2.1." OASIS Standard, 10 June 2021. Used for the explanation of exchanging threat intelligence between systems. https://docs.oasis-open.org/cti/taxii/v2.1/os/taxii-v2.1-os.html
9. **MITRE ATT&CK.** "Adversary-in-the-Middle: DHCP Spoofing (T1557.003)." Used for the discussion of malicious DHCPv6 configuration and IPv6 router advertisements. https://attack.mitre.org/techniques/T1557/003/
10. **Microsoft Learn.** "Guidance for configuring IPv6 in Windows for advanced users." Updated 12 February 2026. Used to distinguish unbinding IPv6 from a network adapter from removing IPv6 from Windows, and to consider Microsoft's configuration guidance. https://learn.microsoft.com/en-us/troubleshoot/windows-server/networking/configure-ipv6-in-windows